Introduction to Cryptography

Lecture 41: Intruders and Intrusion Detection Systems

Dr. Siddhant Thapliyal

Department of Computer Science and Engineering
Graphic Era (Deemed to be University), Dehradun

Learning objectives

- Distinguish three intruder classes
- Describe intrusion behavior and common entry points
- Compare statistical and rule-based IDS
- Interpret audit records and detection errors

What is an intruder?

- An actor who gains unauthorized access or misuses privileges
- Threats range from unauthorized reading to disruption
- Intrusion detection supplements prevention

Three intruder classes

- Masquerader: outsider using another account
- Misfeasor: legitimate user misusing privileges
- Clandestine user: obtains supervisory control and evades audit

Masquerader example

- A stolen account is used to log in
- The attacker activity may differ from the owner profile
- Authentication and behavioral monitoring are complementary

Misfeasor example

- An employee copies records outside their job role
- The login itself is legitimate
- Least privilege and detailed audit trails matter

Clandestine user example

- Privileged control can suppress logging
- Ordinary user-profile detection may fail
- Protect log integrity and administrative access

Intrusion objectives

- Access protected information
- Modify data without permission
- Disrupt availability
- Escalate from low to high privilege

Behavior patterns: hacker

- Reconnaissance of exposed services
- Exploration of vulnerabilities
- Credential compromise and lateral movement
- Illustrative pattern from the supplied chapter

Behavior patterns: criminal enterprise

- Target valuable data
- Act quickly to minimize detection
- Seek persistence or a route back in
- Monitor high-value systems and data movement

Behavior patterns: insider

- Unexpected access to restricted resources
- Large downloads or file copies
- Off-hours activity
- Anomalies are indicators, not proof

Intrusion techniques

- Password guessing and reused credentials
- Trojan software and social engineering
- Exploiting vulnerable services
- Privilege escalation

Password-file protection

- Use a one-way password verifier
- Restrict access to credential databases
- These controls are complementary

Prevention and detection

- Prevention attempts to block compromise
- Detection identifies suspicious activity before or after compromise
- Rapid detection can reduce damage and support investigation

Why IDS is challenging

- Legitimate and attacker behavior overlap
- False positive: normal activity flagged
- False negative: intrusion missed
- Threshold choice creates a trade-off

Statistical anomaly detection

- Learn baseline behavior from audit history
- Threshold detection: count events in a time window
- Profile-based: compare activity to user baseline

Rule-based detection

- Anomaly rules: deviations from learned usage
- Penetration identification: patterns of known attacks
- Rule maintenance and coverage are important

Statistical vs rule-based IDS

- Statistical: learns normal patterns; may flag novel behavior
- Rule-based: explicit rules; interpretable known indicators
- Combining both can improve coverage

Audit records

- Subject: initiator of action
- Action and object: what happened and to what
- Exception condition and resource usage
- Timestamp: when the event occurred

Audit data sources

- Native OS audit records: convenient but variable
- Detection-specific records: targeted and portable
- Standardization eases correlation across systems

Profile metrics

- Counter: login failures per minute
- Gauge: current number of connections
- Interval timer: time between logins
- Resource utilization: CPU or I/O consumed

Statistical models

- Mean and standard deviation
- Multivariate correlation
- Markov state transitions
- Time-series and operational thresholds

Rule-based penetration identification

- Match events to suspicious patterns
- Aggregate evidence into a suspicion score
- Alert when a threshold is exceeded
- Rules must adapt to new techniques

Base-rate fallacy

- Real intrusions may be rare compared with normal activity
- Even a low false-positive rate can create many false alerts
- Interpret alerts using context and multiple signals

Distributed IDS architecture

- Host agents gather endpoint audit events
- LAN monitor agents inspect traffic
- Central manager correlates reports
- Protect confidentiality and integrity of reports

Honeypots

- Decoy resources attract unauthorized interaction
- Collect attacker behavior safely in isolated environments
- Never expose production data through decoys

IDS vs IPS

- IDS detects and alerts
- IPS can actively block selected traffic or actions
- Prevention actions require careful false-positive handling

Class exercise

- A user logs in from an unusual place and copies many files
- Identify possible intruder class
- Choose useful audit fields and detection metrics
- Discuss false-positive explanations

Practice questions

- Compare masquerader, misfeasor and clandestine user
- Explain native and detection-specific audit records
- Differentiate statistical and rule-based IDS
- Explain the base-rate fallacy

Lecture Feedback



Please scan the QR code and share your lecture feedback.